

Data Protection and Privacy Policy

Document ID: POL-DP-001

Version: 3.2

Effective Date: January 15, 2025

Last Reviewed: January 10, 2025

Approved By: Chief Privacy Officer, General Counsel

Classification: Internal - Mandatory Compliance

1. Purpose and Scope

1.1 Purpose

This policy establishes the mandatory framework for the collection, processing, storage, transfer, and destruction of personal data and confidential business information across all operations of Meridian Holdings Group ("the Company"). This policy ensures compliance with applicable data protection regulations including but not limited to the General Data Protection Regulation (GDPR), California Consumer Privacy Act (CCPA), and local data protection laws in all jurisdictions where the Company operates.

1.2 Scope

This policy applies to:

- All employees, contractors, consultants, temporary workers, and third parties who access, process, or handle Company data
- All departments and business units within the Company and its subsidiaries
- All data processing activities regardless of whether conducted manually or through automated systems
- All third-party vendors, service providers, and partners who process data on behalf of the Company
- All geographic locations and jurisdictions where the Company conducts business

1.3 Definitions

- **Personal Data:** Any information relating to an identified or identifiable natural person, including but not limited to name, identification number, location data, online identifier, or factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.
- **Sensitive Personal Data:** Personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data, data concerning health, or data concerning a person's sex life or sexual orientation.
- **Data Controller:** The Company entity that determines the purposes and means of processing personal data.
- **Data Processor:** Any entity that processes personal data on behalf of the Data Controller.
- **Data Subject:** An identified or identifiable natural person whose personal data is being processed.

- Processing: Any operation performed on personal data, including collection, recording, organization, structuring, storage, adaptation, alteration, retrieval, consultation, use, disclosure by transmission, dissemination, alignment, combination, restriction, erasure, or destruction.

2. Data Collection Principles

2.1 Lawfulness, Fairness, and Transparency

All personal data must be processed lawfully, fairly, and in a transparent manner. Before any data collection activity, the responsible department must identify and document the lawful basis for processing. Acceptable lawful bases include:

- a) Consent of the data subject
- b) Performance of a contract
- c) Compliance with a legal obligation
- d) Protection of vital interests
- e) Performance of a task carried out in the public interest
- f) Legitimate interests pursued by the Company, provided such interests are not overridden by the rights of the data subject

2.2 Purpose Limitation

Personal data must be collected for specified, explicit, and legitimate purposes and must not be further processed in a manner incompatible with those purposes. Any new processing activity that deviates from the original stated purpose requires a new privacy impact assessment and, where applicable, fresh consent from the data subject.

2.3 Data Minimization

Only personal data that is adequate, relevant, and limited to what is necessary for the stated purpose shall be collected. Departments must conduct regular reviews of the data they collect and process to ensure compliance with this principle. Over-collection of data is a policy violation subject to disciplinary action.

2.4 Accuracy

Personal data must be accurate and, where necessary, kept up to date. Every reasonable step must be taken to ensure that inaccurate personal data is erased or rectified without delay. Data subjects must be provided with mechanisms to update their personal information.

2.5 Storage Limitation

Personal data must not be kept in a form that permits identification of data subjects for longer than necessary for the purposes for which it is processed. Specific retention periods are defined in the Company's Data Retention Schedule (Appendix A). Upon expiration of the retention period, data must be securely destroyed in accordance with Section 8 of this policy.

3. Data Processing Requirements

3.1 Privacy Impact Assessments

A Data Protection Impact Assessment (DPIA) must be conducted before initiating any new processing activity that is likely to result in high risk to the rights and freedoms of individuals. This includes:

- Systematic and extensive profiling with significant effects on individuals
- Large-scale processing of sensitive personal data
- Systematic monitoring of publicly accessible areas
- Use of new technologies that may pose privacy risks
- Cross-border data transfers involving sensitive data
- Any processing activity involving children's data

The DPIA must be submitted to the Data Protection Officer (DPO) for review and approval before the processing activity commences. Processing may not begin until written approval is received.

3.2 Records of Processing Activities

Each department must maintain a comprehensive Record of Processing Activities (ROPA) that includes:

- The name and contact details of the data controller and DPO
- The purposes of the processing
- A description of the categories of data subjects and personal data
- The categories of recipients to whom personal data has been or will be disclosed
- Details of transfers to third countries, including documentation of safeguards
- Envisaged time limits for erasure of different categories of data
- A general description of technical and organizational security measures

The ROPA must be updated at least quarterly and made available to supervisory authorities upon request within 72 hours.

3.3 Consent Management

Where processing is based on consent:

- Consent must be freely given, specific, informed, and unambiguous
- Consent must be obtained through a clear affirmative action
- Pre-ticked boxes, silence, or inactivity do not constitute consent
- Data subjects must be informed of their right to withdraw consent at any time
- Withdrawal of consent must be as easy as giving consent
- Records of consent (who, when, what, how) must be maintained for the duration of the processing activity plus three years
- Consent for children under 16 must be given or authorized by the holder of parental responsibility

4. Data Security Measures

4.1 Technical Measures

All systems processing personal data must implement the following minimum technical security measures:

- a) Encryption: All personal data must be encrypted at rest using AES-256 or equivalent encryption standard. Data in transit must be protected using TLS 1.2 or higher. Encryption keys must be managed through a centralized key management system and rotated at least annually.
- b) Access Controls: Role-based access control (RBAC) must be implemented for all systems containing personal data. Access must follow the principle of least privilege. Multi-factor authentication (MFA) is mandatory for all systems containing sensitive personal data.
- c) Logging and Monitoring: All access to personal data must be logged, including the identity of the accessor, timestamp, data accessed, and purpose. Logs must be retained for a minimum of two years and must be tamper-proof. Automated monitoring must be implemented to detect unauthorized access attempts.
- d) Network Security: Systems containing personal data must be isolated in dedicated network segments. Firewalls and intrusion detection/prevention systems must be deployed. Regular vulnerability scanning must be conducted at least monthly, and penetration testing at least annually.
- e) Backup and Recovery: Personal data must be backed up according to the Company's backup policy. Backup copies must be encrypted to the same standard as production data. Recovery procedures must be tested at least semi-annually.

4.2 Organizational Measures

- a) Training: All personnel who process personal data must complete mandatory data protection training within 30 days of commencement of employment and annually thereafter. Specialized training must be provided for personnel handling sensitive personal data.
- b) Confidentiality Agreements: All personnel and third parties with access to personal data must sign confidentiality agreements before being granted access. These agreements must survive termination of employment or contract.
- c) Clean Desk Policy: Physical documents containing personal data must not be left unattended. Documents must be locked in secure cabinets when not in use and shredded when no longer needed.
- d) Incident Response: A dedicated Data Breach Response Team must be established and available 24/7. All personnel must report suspected data breaches to the DPO within 4 hours of discovery.

5. Third-Party Data Processing

5.1 Vendor Assessment

Before engaging any third party to process personal data on behalf of the Company, a comprehensive vendor assessment must be conducted including:

- Review of the vendor's data protection policies and procedures
- Assessment of technical and organizational security measures
- Verification of relevant certifications (ISO 27001, SOC 2, etc.)
- Review of sub-processor arrangements
- Assessment of cross-border data transfer mechanisms
- Financial stability assessment to ensure ongoing capability to meet obligations

5.2 Data Processing Agreements

A written Data Processing Agreement (DPA) must be executed with every third party that processes personal data on behalf of the Company. The DPA must include, at minimum:

- The subject matter, duration, nature, and purpose of the processing
- The types of personal data and categories of data subjects
- The obligations and rights of the Company as data controller
- Requirements for the processor to process data only on documented instructions
- Confidentiality obligations for all personnel of the processor
- Requirements to implement appropriate technical and organizational measures
- Conditions for engaging sub-processors (prior written authorization required)
- Obligations to assist the Company with data subject rights requests
- Requirements to delete or return all personal data upon termination
- Right of the Company to conduct audits and inspections
- Obligation to immediately notify the Company of any data breach
- Specific data residency requirements as defined in Section 5.3

Failure to execute a DPA before data processing commences is a serious policy violation.

5.3 Data Residency Requirements

Personal data of data subjects located in the European Economic Area (EEA) must be stored and processed within the EEA unless:

- a) An adequacy decision exists for the recipient country
- b) Appropriate safeguards are in place (Standard Contractual Clauses, Binding Corporate Rules)
- c) A specific derogation applies under Article 49 of the GDPR

All data residency arrangements must be documented and reviewed annually. The DPO must be notified of any change in data storage location within 48 hours.

5.4 Sub-Processor Management

Third-party processors may not engage sub-processors without prior written authorization from the Company. The processor must:

- Provide the Company with a list of all current sub-processors
 - Notify the Company of any intended changes to sub-processors at least 30 days in advance
 - Ensure sub-processors are bound by the same data protection obligations
 - Remain fully liable for the performance of sub-processor obligations
-

6. Data Subject Rights

6.1 Rights Framework

The Company recognizes and facilitates the following data subject rights:

- a) Right of Access: Data subjects may request confirmation of whether their personal data is being processed and, if so, obtain a copy of that data along with supplementary information about the processing.
- b) Right to Rectification: Data subjects may request correction of inaccurate personal data or completion of incomplete data.
- c) Right to Erasure: Data subjects may request deletion of their personal data where there is no compelling reason for continued processing.
- d) Right to Restriction: Data subjects may request restriction of processing in certain circumstances.
- e) Right to Data Portability: Data subjects may receive their personal data in a structured, commonly used, and machine-readable format.
- f) Right to Object: Data subjects may object to processing based on legitimate interests or for direct marketing purposes.
- g) Rights Related to Automated Decision-Making: Data subjects have the right not to be subject to decisions based solely on automated processing that produce legal effects or similarly significant effects.

6.2 Response Procedures

All data subject requests must be acknowledged within 3 business days and fulfilled within 30 calendar days of receipt. If an extension is necessary due to complexity or volume of requests, the data subject must be notified within the initial 30-day period, and the extension may not exceed an additional 60 days.

Identity verification must be conducted before fulfilling any request. Requests may be refused only where they are manifestly unfounded or excessive, and the reasons for refusal must be documented and communicated to the data subject.

7. Data Breach Management

7.1 Breach Notification to Supervisory Authority

In the event of a personal data breach that is likely to result in a risk to the rights and freedoms of individuals, the DPO must notify the relevant supervisory authority within 72 hours of becoming aware of the breach. The notification must include:

- The nature of the breach, including categories and approximate number of affected data subjects
- The name and contact details of the DPO
- The likely consequences of the breach
- The measures taken or proposed to address the breach

7.2 Breach Notification to Data Subjects

Where a personal data breach is likely to result in a high risk to the rights and freedoms of individuals, the affected data subjects must be notified without undue delay. The notification must be in clear, plain language and include the same information provided to the supervisory authority, along with specific recommendations for protective measures.

7.3 Breach Documentation

All data breaches, regardless of severity, must be documented in the Company's Breach Register, including the facts of the breach, its effects, and the remedial actions taken. The Breach Register must be retained for a minimum of five years.

8. Data Retention and Destruction

8.1 Retention Periods

Personal data must be retained only for the period necessary to fulfill the purpose for which it was collected. Standard retention periods are:

Data Category	Retention Period
Employee records	Duration of employment + 7 years
Customer transaction data	7 years from date of transaction
Marketing consent records	Duration of consent + 3 years
CCTV footage	30 days unless required for investigation
Website analytics	26 months
Recruitment data (unsuccessful)	12 months from decision
Contract records	Duration of contract + 10 years

Health and safety records	40 years
---------------------------	----------

8.2 Secure Destruction

When personal data reaches the end of its retention period, it must be securely destroyed using methods appropriate to the medium:

- Electronic data: Secure deletion using certified data wiping software, or physical destruction of storage media
- Paper documents: Cross-cut shredding (minimum DIN 66399 security level P-4)
- Backup media: Degaussing and physical destruction

Destruction must be documented, including the date, method, description of data destroyed, and identity of the person responsible for destruction.

9. International Data Transfers

9.1 Transfer Mechanisms

Personal data may be transferred outside the jurisdiction of collection only through approved transfer mechanisms:

- Adequacy decisions by relevant regulatory authorities
- Standard Contractual Clauses approved by the European Commission
- Binding Corporate Rules approved by the relevant supervisory authority
- Explicit consent of the data subject (only for occasional, non-systematic transfers)
- Performance of a contract at the request of the data subject

9.2 Transfer Impact Assessments

Before initiating any international data transfer, a Transfer Impact Assessment (TIA) must be conducted to evaluate the level of data protection in the recipient country. The TIA must consider:

- The legal framework of the recipient country
 - Access to data by public authorities in the recipient country
 - The existence and effectiveness of data protection authorities
 - International commitments of the recipient country
 - Any supplementary measures necessary to ensure adequate protection
-

10. Compliance and Enforcement

10.1 Monitoring and Auditing

The DPO will conduct regular audits of data processing activities to ensure compliance with this policy. Audits will be conducted:

- Annually for all departments
- Quarterly for high-risk processing activities
- Upon notification of a data breach
- Before and after significant changes to processing activities

10.2 Violations and Disciplinary Action

Violations of this policy may result in disciplinary action up to and including termination of employment or contract. Serious violations may be reported to relevant supervisory authorities and may result in personal liability for the individuals involved. The Company reserves the right to seek damages from individuals or entities whose policy violations result in regulatory fines or other financial losses.

10.3 Policy Review

This policy shall be reviewed annually or more frequently if required by changes in applicable law, regulatory guidance, or the Company's business operations. All changes must be approved by the Chief Privacy Officer and General Counsel.

Appendix A: Data Retention Schedule - See separate document POL-DP-001-A

Appendix B: DPIA Template - See separate document POL-DP-001-B

Appendix C: Data Breach Response Procedure - See separate document POL-DP-001-C

Appendix D: Approved International Transfer Mechanisms - See separate document POL-DP-001-D